TEK1314 | KEL. 12



SKENARIO 10: IOT PROTOCOL GUARDIAN

PBL

Pengujian Keamanan Backend SmartCow Sprinkler

Kelompok 12 - Kelas B (PBL Keamanan Siber):

- **Thevan Erlangga (J0404241073) :** *Lead & Purple Team Coordinator*
- **Muhamad Akhdan Ramadhan (J0404241102) :** *Red Team (Offensive Security)*
- **Fachri Abyasa Tarid (J0404241136) :** *Blue Team (Defensive & Hardening)*

Teknologi Rekayasa Komputer • Institut Pertanian Bogor (IPB University)

Checkpoint Fase 1 ke 2

01. LATAR BELAKANG

Konteks Proyek IoT: SmartCow

Sistem Sprinkler Otomatis Kandang Sapi

• **Sensor Lingkungan:** 6 sensor suhu DS18B20 dan 4 sensor kelembapan DHT22 terdistribusi pada dua unit mikrokontroler ESP32.
• **Agregasi & Telemetri:** ESP kanan mengagregasi data suhu/kelembapan, lalu mengirim telemetri ke Firebase Realtime Database (RTDB) via HTTPS REST.
• **Dashboard Web Peternak:** Antarmuka Firebase Hosting dipakai peternak memantau kondisi kandang real-time & mengatur ambang batas penyiraman.
• **Aktuator Pompa 220V:** Relay GPIO23 menjaga solenoid valve air dengan logika hysteresis, durasi maksimum semprot, dan waktu pendinginan (cooldown).

Identifikasi Celah Keamanan Kritis (Vulnerability)

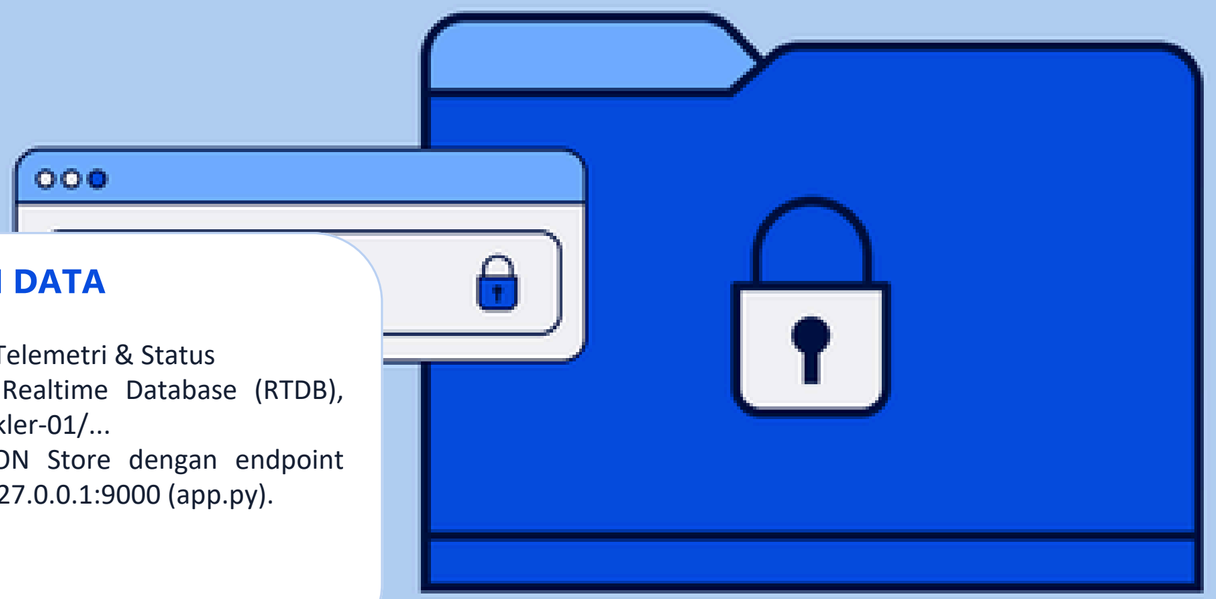
• **Hardcoded Database Secret:** Kredensial master Firebase RTDB tertanam langsung secara plaintext dalam esp32/src/main.cpp (?auth=), rawan diekstraksi.
• **TLS setInsecure() Aktif:** Firmware mematikan verifikasi sertifikat root CA, membuka celah penyadapan & Man-in-the-Middle (MitM) pada jalur internet.
• **ESP-NOW Tanpa Enkripsi:** Jalur komunikasi nirkabel antar ESP32 (2,4 GHz) berjalan tanpa sandi cipher, memungkinkan injeksi paket telemetri palsu.



02. TECH STACK

02. DEKLARASI TEKNOLOGI

Pemetaan Stack Asli vs Replika Lab



1. BACKEND SERVER OS

Komponen: Sistem Operasi Layanan Backend
Proyek Asli: Infrastruktur Firebase terkelola Google (Serverless tanpa manajemen OS host).
Replika Lab: Arch Linux Security Workstation pada SRV-IOT-KEL12-B (192.168.12.5), dikelola unit systemd.

2. PENYIMPANAN DATA

Komponen: Basis Data Telemetri & Status
Proyek Asli: Firebase Realtime Database (RTDB), path devices/cow-sprinkler-01/...
Replika Lab: Local JSON Store dengan endpoint REST bergaya RTDB di 127.0.0.1:9000 (app.py).

3. PROTOKOL SENSOR

Komponen: Komunikasi Sensor ke Backend
Proyek Asli: HTTPS REST dengan Database Secret, ESP32 mengirim telemetri tiap 2 detik.
Replika Lab: HTTP REST + Token Bearer, simulator Python 3.9 (dummy telemetri tiap 2 detik).

4. DASHBOARD & PROXY

Komponen: Antarmuka Web & Gateway
Proyek Asli: Firebase Hosting, HTML5 & JavaScript statis memanggil RTDB.
Replika Lab: Nginx 1.18.0 Reverse Proxy (/api diteruskan ke loopback port 9000).

5. AUTH & BROKER MQTT

Komponen: Keamanan Akses & Broker Pesan
Proyek Asli: Firebase Authentication & Rules RTDB (Database Secret statis).
Replika Lab: Token Bearer internal, Broker MQTT mandiri (broker.py) port 1883 ber-auth & ACL topik.

03. SIMULASI JARINGAN

Topologi Lab Terisolasi 192.168.12.0/24

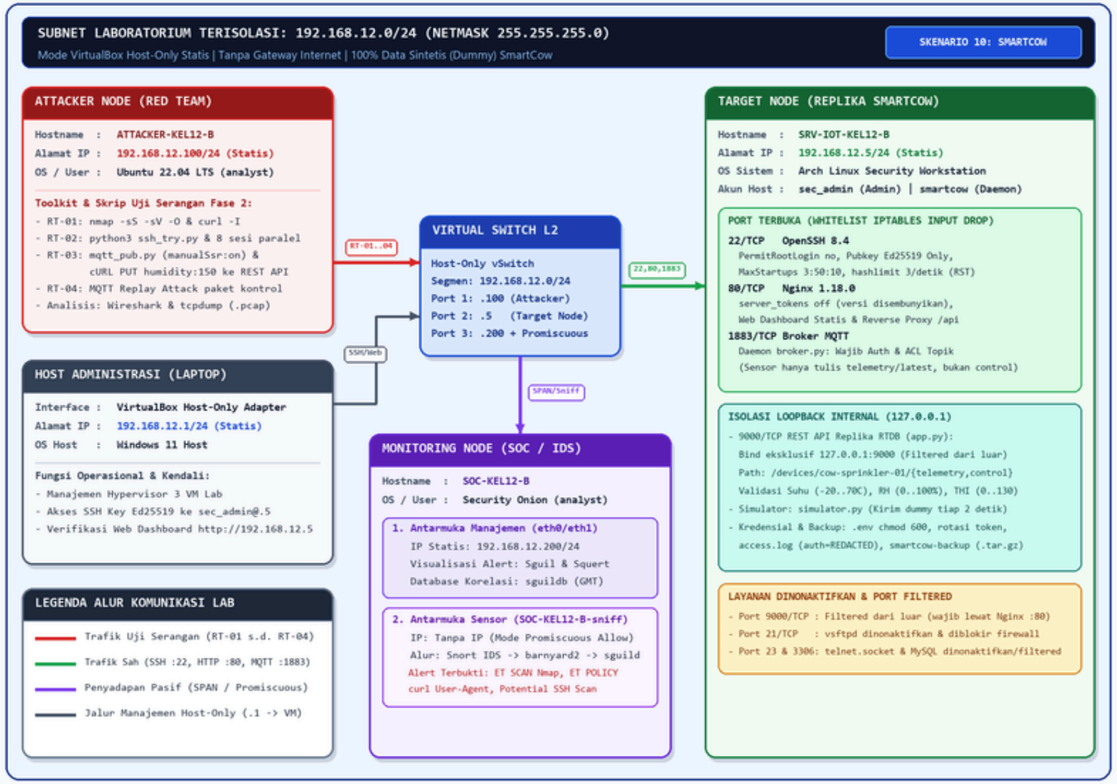
Node Attacker & Target (Lab Host-Only)

- **ATTACKER (192.168.12.100):** LabVM Ubuntu 22.04 LTS (ATTACKER-KEL12-B). Toolkit: nmap, Wireshark, tcpdump, dan cURL, ssh_try.py, dan mqtt_pub.py.
- **TARGET NODE (192.168.12.5):** Arch Linux Security Workstation (SRV-IOT-KEL12-B). Menjalankan replika IoT: SSH (22), Nginx (80), MQTT (1883), dan REST API loopback (127.0.0.1:9000).
- **Isolasi Subnet:** Seluruh interaksi berlangsung pada segmen 192.168.12.0/24 statis tanpa gateway ke internet.

Node Monitoring SOC & Host Administrasi

- **SOC MONITORING (192.168.12.200):** Security Onion (SOC-KEL12-B). Antarmuka manajemen untuk observasi Sguil & Squert; antarmuka sensor promiscuous menangkap paket jaringan.
- **HOST LAPTOP (192.168.12.1):** Windows VirtualBox Host-Only Adapter. Digunakan mengelola VM & verifikasi akses web dashboard tanpa jalur routing keluar.
- **Keamanan Eksperimen:** Data yang dipakai adalah 100% data dummy; tidak ada lalu lintas yang menyentuh server produksi fisik.

DIAGRAM TOPOLOGI & ARSITEKTUR SIMULASI LAB (192.168.12.0/24)



04. BLUE TEAM

04. HARDENING STATUS

Progres Hardening: 9 Kontrol (100% DONE)

Kategori A: Access & Authentication (3 Kontrol DONE)

• **Kontrol A1 (Tolak Login Root):** Konfigurasi PermitRootLogin no pada SSH daemon. Menghilangkan risiko serangan langsung ke akun superuser.
• **Kontrol A2 (Kunci Publik Tanpa Sandi):** PasswordAuthentication no. Akses SSH hanya diizinkan via pasangan kunci Ed25519/RSA milik analis.
• **Kontrol A3 (Batas Laju & Percobaan): MaxStartups 3:50:10 pada sshd & modul iptables hashlimit (maks 3 koneksi/detik, burst 6, TCP RST) meredam banjir sesi.**

Kategori B & C: Surface & Data Application (6 Kontrol DONE)

• **Kontrol B1 (Firewall Whitelist Persisten):** iptables default policy DROP; hanya mengizinkan port 22, 80, 1883 dari 192.168.12.0/24. Disimpan persisten di /etc/iptables/iptables.rules.
• **Kontrol B2 (Isolasi Port API):** REST service (port 9000) hanya terikat pada loopback 127.0.0.1. Akses luar wajib melalui reverse proxy Nginx ber-token.
• **Kontrol B3 (Sembunyikan Banner):** Konfigurasi server_tokens off pada Nginx menyembunyikan versi web server dari pemindaian nmap.
• **Kontrol C1 (Validasi & ACL MQTT): Validasi rentang suhu/kelembapan (0-100%) & ACL topik cow-sprinkler-01/control memblokir injeksi liar.**
• **Kontrol C2 & C3 (Kredensial & Backup): Izin .env mode 600 (user smartcow), rotasi token openssl, log auth=REDACTED, dan skrip smartcow-backup.**



05. IMPLEMENTASI TEKNIS

Matriks Verifikasi 9 Kontrol Hardening

ID	Kategori	Fokus Kontrol	Sebelum Hardening (Vulnerable)	Sesudah Hardening (Hardened)	Status
A1	Access & Auth	Tolak Login Root	Login root dengan password diterima	PermitRootLogin no, login ditolak	DONE
A2	Access & Auth	Autentikasi SSH	Password auth aktif, rawan brute-force	PasswordAuthentication no, wajib key	DONE
A3	Access & Auth	Rate Limit SSH	MaxStartups 10:30:100, tanpa rate limit paket	MaxStartups 3:50:10 & hashlimit 3/s (TCP RST)	DONE
B1	Attack Surface	Firewall Whitelist	Port lab terbuka tanpa filter ketat	Default DROP, port 22,80,1883 persisten	DONE
B2	Attack Surface	Isolasi Port API	API port 9000 bind 0.0.0.0 terbuka luas	Bind 127.0.0.1, filtered dari luar	DONE
B3	Attack Surface	Header Server	Nginx 1.18.0 terpapar jelas di header	server_tokens off, versi disembunyikan	DONE
C1	Data & App	Validasi & ACL MQTT	Kelembapan 150% diterima & publish MQTT anonim	Validasi suhu/RH (0-100%) & wajib auth ACL MQTT	DONE
C2	Data & App	Isolasi Kredensial	Berkas .env mode 644 & token literal di app.py	Izin 600 (user smartcow), env var & rotasi token	DONE
C3	Data & App	Logging & Backup	Log tercecer, tanpa snapshot data berkala	Log auth=REDACTED & skrip smartcow-backup aktif	DONE

06. SKENARIO SERANGAN

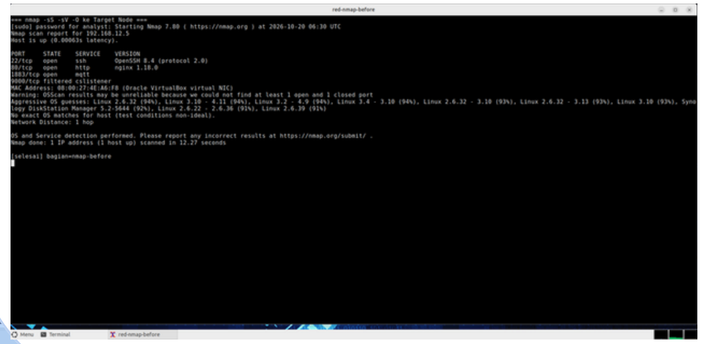
Rencana & Eksekusi RT-01 s/d RT-04

Parameter Uji & Bukti Log Penyerangan

- **Source IP:** 192.168.12.100 (ATTACKER-KEL12-B)
- **Target IP:** 192.168.12.5 (SRV-IOT-KEL12-B)
- **Log Pengujian Ping:** ping 192.168.12.5 -> 0% packet loss, RTT avg 1,202 ms (GPL ICMP_INFO PING di Sguil).

```
Cuplikan Log Nmap Awal (Fase 1):
PORT 22/tcp  open  ssh    OpenSSH 8.4
PORT 80/tcp  open  http   nginx 1.18.0
PORT 1883/tcp open  mqtt   broker.py (tanpa auth)
PORT 9000/tcp open  REST API app.py (0.0.0.0)
```

- **Evaluasi Offensive:** Pada kondisi awal, seluruh attack surface backend terbuka tanpa rintangan. Penyerang bebas melakukan profiling dan injeksi langsung ke port 9000.



4 Skenario Serangan Red Team (Fase 2):

RT-01: Reconnaissance & Port Scanning

Alat: nmap -sS -sV -O -p 22,80,1883,9000 192.168.12.5 & curl -I. Sasaran: Memetakan port terbuka, banner Nginx, dan eksposur API.

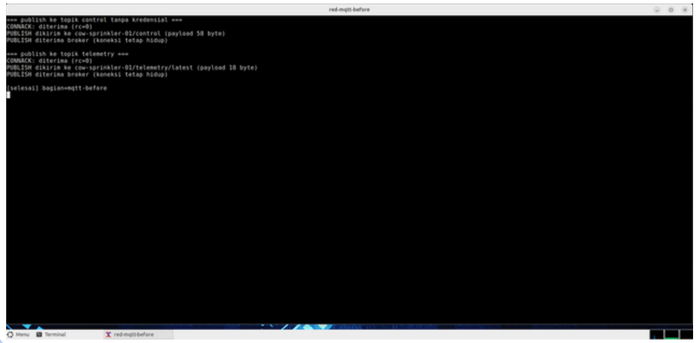
RT-02: SSH Brute-Force & Credential Attack

Alat: python3 ssh_try.py (root & sec_admin) & 8 sesi paralel. Sasaran: Menguji autentikasi kunci publik & batas laju port 22.

RT-03 & RT-04: Injeksi REST, MQTT Publish Liar & Replay Attack

Alat: mqtt_pub.py ke cow-sprinkler-01/control ('{"manualSsr":"on"}'), cURL PUT humidity:150, & replay paket kendali pompa saat idle.

Sasaran: Menguji ACL topik kontrol, validasi rentang sensor, dan penolakan paket usang.



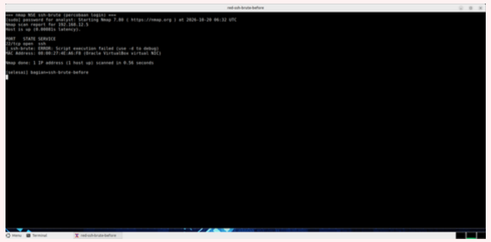
07. EVALUASI PURPLE TEAM

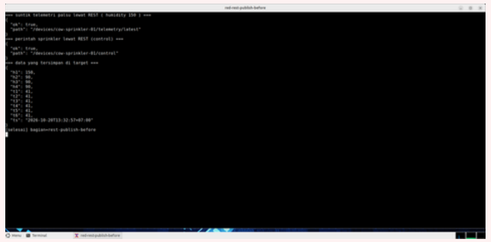
Hasil: Sebelum vs Sesudah Hardening

IoT

Kondisi Sebelum Hardening (Fase 1 - Vulnerable)

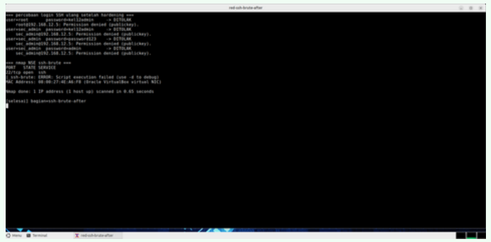
✗ **Port Scanning (RT-01):** Port 22, 80, 1883, dan 9000 terbuka bebas. Nginx 1.18.0 & OpenSSH terdeteksi jelas tanpa proteksi.
✗ **Akses SSH (RT-02): Akun sec_admin berhasil dimasuki dengan sandi sederhana tanpa pembatasan jumlah sesi paralel.**
✗ **Injeksi REST API (RT-03): Request PUT dengan kelembapan 150% diterima backend (HTTP 200) dan merusak data telemetri.**
✗ **MQTT Publish Liar (RT-03): Broker menerima publish anonim {"manualSsr":"on"} ke topik cow-sprinkler-01/control.**
✗ **Kesimpulan Tahap 1:** Seluruh skenario serangan Red Team dinyatakan BERHASIL menembus pertahanan awal target.

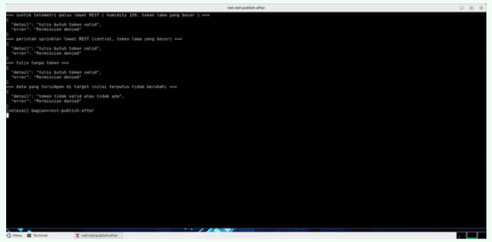




Kondisi Sesudah Hardening (Fase 2 - Hardened)

✓ **Reconnaissance Dibatasi:** Port 9000 terblokir (filtered) oleh iptables. Banner Nginx disembunyikan (server_tokens off).
✓ **SSH Terkunci Total: Login root & sandi ditolak (Permission denied publickey); banjir sesi di-reset hashlimit iptables.**
✓ **REST API Terproteksi: Kelembapan 150% ditolak (HTTP 400 Bad Request); akses tanpa token sah ditolak (HTTP 401 Unauthorized).**
✓ **MQTT Otentikasi & ACL: Klien anonim ditolak (CONNACK 5); penulisan topik cow-sprinkler-01/control oleh sensor diblokir ACL.**
✓ **Evaluasi Purple Team:** Semua serangan yang semula sukses pada Tahap 1 BERAKHIR GAGAL pada Tahap 5 sesuai panduan PBL.





08. MONITORING & PEMBELAJARAN

Deteksi Security Onion & Kendala Lab

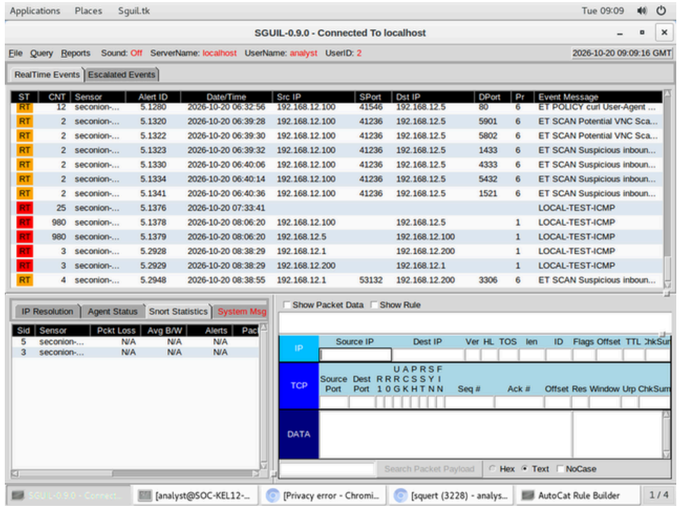
1. Deteksi IDS Security Onion (Snort & Sguil)

- **Sensor Promiscuous:** Antarmuka sniffing menangkap seluruh trafik dari 192.168.12.100 menuju 192.168.12.5.
- **Alert Sguil Escalated Events: Jam 06:30-06:47 GMT (13:30-13:47 WIB): ET SCAN Nmap, ET POLICY curl User-Agent (:80), dan ET SCAN Potential SSH Scan (:22).**
- **Baseline Traffic Normal:** Simulator telemetri dummy tiap 2 detik berhasil dikenali sebagai trafik normal oleh NIDS.

2. Kendala Operasional Laboratorium & Solusi Tim

- **Akses Security Onion:** Antarmuka manajemen SO tidak merespons ARP dari host & tidak ada SSH server. -> Solusi: Observasi dan bukti alert diambil manual dari layar console VM Onion.
- **Lab Offline Tanpa Internet:** Paket fail2ban, hydra, mosquitto tidak bisa diunduh via pacman/apt. -> Solusi: Membangun modul app.py, broker.py, ssh_try.py, dan mqtt_pub.py berbasis pustaka standar Python 3.9.
- **Persistensi Firewall:** Aturan iptables sempat hilang saat Target di-reboot. -> Solusi: Aturan disimpan permanen ke /etc/iptables/iptables.rules dan dimuat otomatis via service systemd.

BUKTI ALERT SGUIL (docs/blueteam/evidence/sguil-alert-minggu9.png)



Analisis Alert Sguil:

- Sensor Security Onion mendeteksi percobaan nmap NSE scan pada port 80 target.
- IP Penyerang (192.168.12.100) tercatat jelas pada kolom Source IP.
- Alert berkorelasi langsung dengan log terminal pada host penyerang.

09. REKOMENDASI & TANYA JAWAB

Rekomendasi Proyek Asli & Penutup

Rekomendasi Mitigasi untuk Sistem Asli SmartCow

- **1. Rotasi Database Secret:** Segera cabut secret Firebase yang tertanam pada sketch firmware fisik & gunakan token temporer berbasis Firebase Auth.
- **2. Hapus setInsecure():** Terapkan validasi sertifikat SSL/TLS dengan mengimpor root CA fingerprint Firebase ke mikrokontroler ESP32.
- **3. Enkripsi ESP-NOW:** Pasang Primary Master Key (PMK) & Local Master Key (LMK) AES-128 untuk mengamankan link nirkabel antar ESP32.
- **4. Broker MQTT Otentikasi:** Gunakan MQTTS (port 8883) dengan enkripsi TLS serta otorisasi topik berbasis ACL per mikrokontroler.



Identitas Tim & Repositori Proyek

- **Kelompok 12 - Kelas B | TEK1314 PBL Keamanan Siber**
- **Thevan Erlangga (J0404241073):** Lead & Purple Team Coordinator
- **Muhamad Akhdan Ramadhan (J0404241102):** Red Team (Offensive Security)
- **Fachri Abyasa Tarid (J0404241136):** Blue Team (Defensive & Hardening)
- **Repository GitHub:** github.com/SwipeLz/TEK1314-2026-Kel-12-Kelas-B

Wajib Unggah Sebelum Sesi: docs/presentation-minggu9/slides.pdf (PDF) • Terima Kasih & Q&A